

CLAUDE CODE MEETUP

AI-Native Security in Software Development

| Meet the Speaker



Jozsef Ottucsak

Product Security Architect @ Diligent

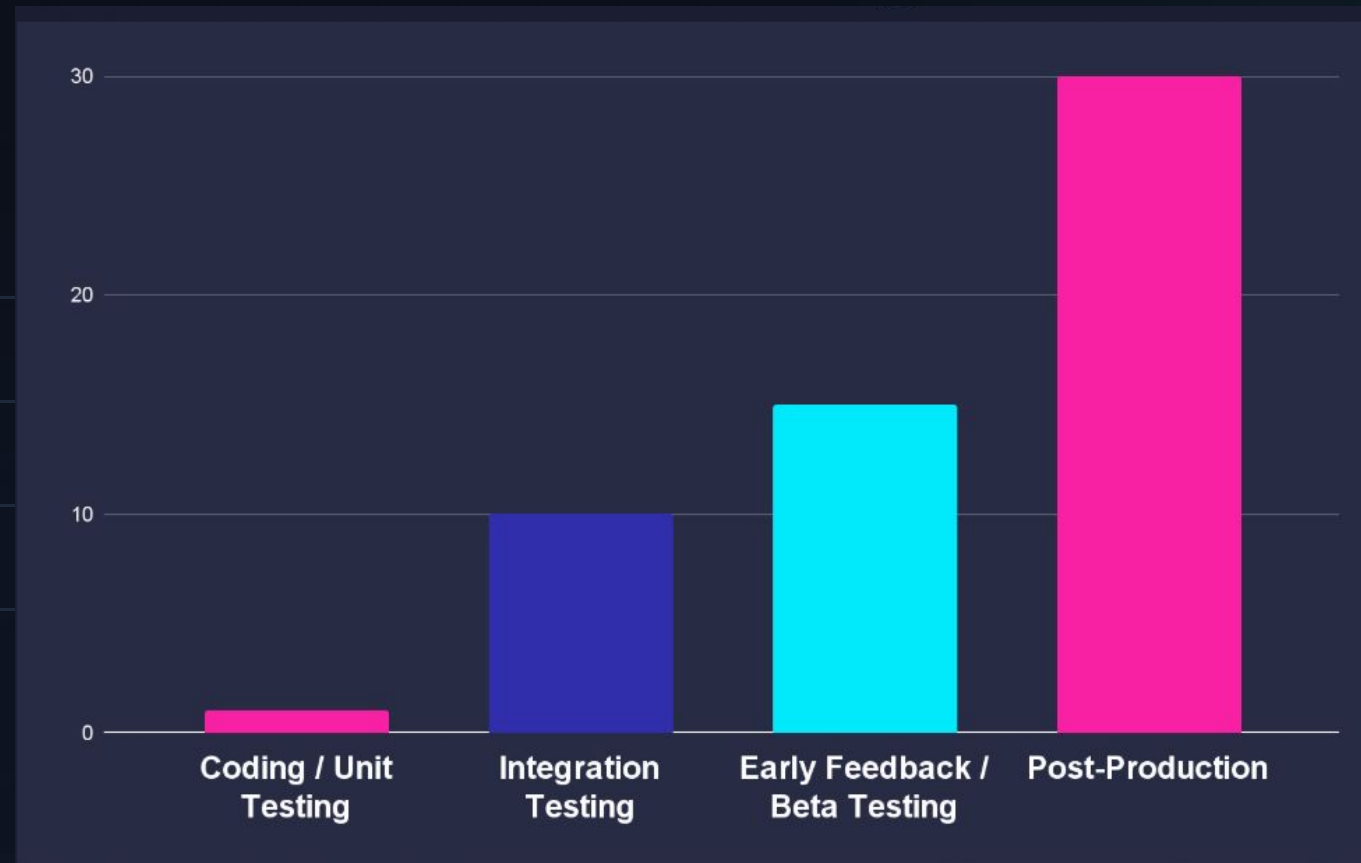
Over a decade of security engineering experience at SaaS companies. Passionate about software quality, craftsmanship, security and AI/ML. OSCP, CISSP, MSc, MBA, ISO 42001 certifications.

Currently focusing on securing agentic development initiatives, agentic workloads and automating security initiatives using agents.

| Why Should You Care?

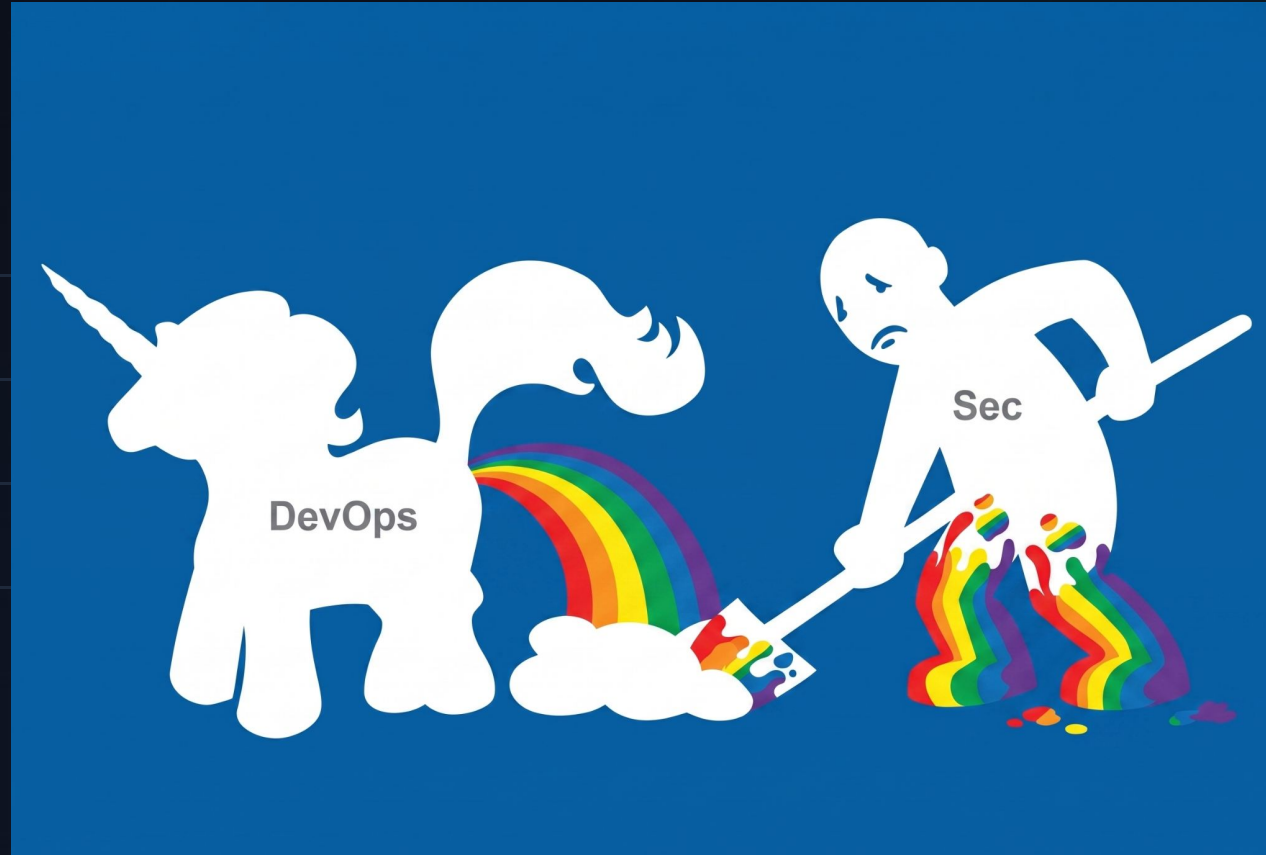
	Amazon	CRITICAL	6-hour outage wipes 99% of U.S. order volume	 ~6.3 million lost orders	 Production Outages	Mar 5, 2026	▼
	Amazon	HIGH	Incorrect delivery times appear in shopping carts	 ~120,000 lost orders	 Production Outages	Mar 2, 2026	▼
	DataTalks.Cl...	CRITICAL	Claude Code runs terraform destroy, ...	 1.94M rows lost, 100K+ students affected	 Production Outages	Mar 2026	▼
	Orchids	CRITICAL	Zero-click hack hijacks BBC reporter's laptop in live demo	 1M+ platform users at risk	 Data Exposures	Feb 2026	▼
	Moltbook	CRITICAL	Misconfigured database exposes 1.5M auth toke...	 1.5M tokens + 35K emails exposed	 Data Exposures	Feb 2026	▼
	Meta	HIGH	AI agent posts incorrect security g...	 2-hour unauthorized access to sensitive code	 Production Outages	Jan 2026	▼
	5,600 Vibe-...	CRITICAL	2,000+ vulnerabilities and 400+ exposed sec...	 2,000+ vulns, 400+ exposed secrets	 Data Exposures	2026	▼
	OpenClaw	CRITICAL	CVE-2026-31992: allowlist bypass via env -S, CVS...	 CVSS 9.9, full guardrail bypass	 Insecure AI Code	2026	▼

| Cost of Fixing Bugs in SDLC

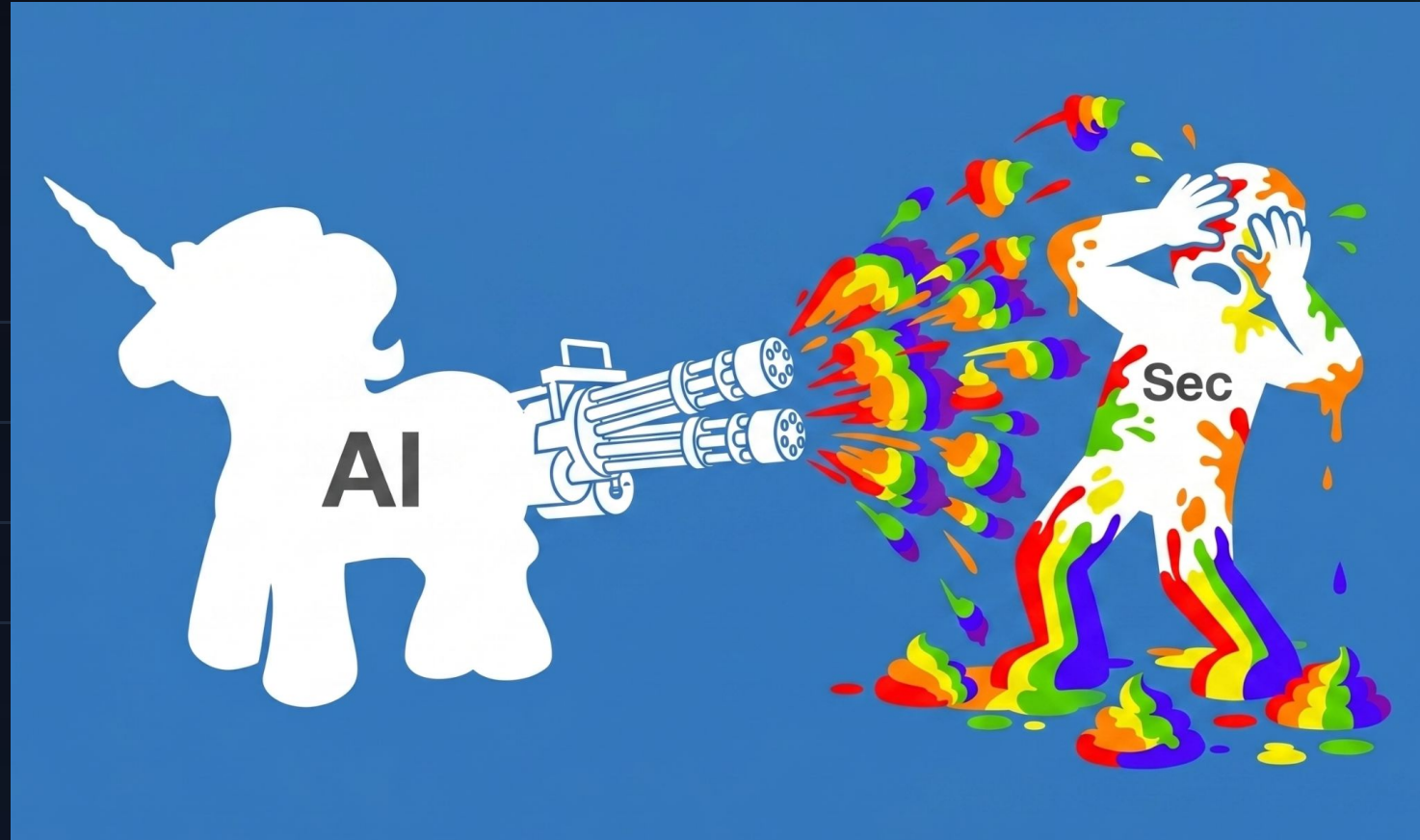


Source: HackerOne (<https://www.hackerone.com/blog/cost-savings-fixing-security-flaws>)

| Old Days



| Happy New Days



| The Review Problem

100x

CODE GENERATION SPEED

Humans Out of the Loop

AI writes code at a faster pace than we can understand. Human attention is finite and cannot scale. → *human review is a bottleneck*

Vibe coded changes can be excessively big, overengineered, under engineered, sloppy or poorly implemented → *harder to review*

Velocity increase means more reviews, more tickets to handle, more context switching → *less attention per change*

| How The New **Claude Security Guidance** Does It

- 🔍 **Edit:** Simple pattern matching (eval, deserialization, command injection, etc)
- ⚠️ **After Turns:** Separate security background agent reviews changes
- 🔄 **Commit/push:** Triggers deeper agentic security review

Claude Code: `/plugin install security-guidance@claude-plugins-official`

Info: <https://code.claude.com/docs/en/security-guidance>

| Agentifying Security

Objective

Preventing token waste by rejecting vulnerable plans

Finding security problems early

Assisting security team with risk mapping

| Pre-Code Security Phases

Security Architecture Review

Evaluating application architecture including trust boundaries, and high level changes influencing behavior of the system..

Requires known standards, previous architectural decisions and up-to-date information.

Security Design Review

Checking proposed application specs against functional security standards before source-control commits.

Requires knowing how multiple systems interact, implementation related standards and best practices.

Agentified Security Reviews

Offloading reviews to agents works okay-ish, e.g. better than nothing. It's okay for sanity check, but agents are opportunistic -leading to **low business value findings**

Security code smells often marked as **CRITICAL** while fundamental problems are not identified.

| Security as a Native NFR



AGENTS.MD/SECURITY.MD

Project level security requirements, baselines, goals should be documented. Keep it small and general, refer to standards instead of inlining every single requirement.



Coding Style

Enforces standards that make code harder to read/troubleshoot, eg. max lines of code per function, multiple returns, unreadable code. Implicit security impact.



Security Tests

Automated tests against known bad behavior like RBAC regression, new unauthenticated endpoints, etc.

Agents CAN AND WILL bypass them!

| Deterministic Security Tooling

Static Analysis

Security checks analysing raw code, package definitions or built artifacts.

- Secret scanner
- Software composition analysis
- Static application security testing
- Container scanning
- IaC security scanning

Dynamic Analysis

Verifying the deployed/running application or environment.

- Dynamic app security testing
- Network security tools
- Runtime app sec tools
- Fuzzer
- Cloud Security Posture Management

| Autonomy vs. Certainty

DETERMINISTIC	Computationally cheap and usually quick, but lacks understanding of codebase
AGENTIC	Autonomous analysis and decision making, but expensive
HYBRID	Deterministic Tools & Agentic Analysis → Agentic Triage → Agentic Remediation

Agentic CI/CD Pipelines

Agentic CI/CD pipelines unlock new attacks and amplify existing risks. CI/CD/software supply chain security is hard, especially for codebases receiving external contributions. (See: `{{ github.event.issue.title }}`)

Before throwing agents into the CI/CD, consider the cost of execution at scale.

See OWASP Top 10 CI/CD Security Risks and OWASP Top 10 for Agentic Applications

| Tool Problems

Writing Custom Security Agents

Writing reliable security tools is hard. Happy path is easy, fine tuning for different codebases and reliable operation is hard.

Agentic workloads need constant attention, evals, tuning and monitoring.

- 🔒 **Automation Maintenance:** Something will eventually break - use only reliable tools and have bypass switch.
- ⚠️ **False Positives:** Even when grounded by tool calls, false positives still happen.
- 🔊 **Inflated Severity:** According to agents EVERYTHING is high or critical. They have zero chill.
- 🔄 **Infinite Loop Patches:** Resolving alerts automatically can trigger recursive loops.
- 🔒 **No Sense of Pain:** Agents often over or underestimate the work it takes to fix something and will give bad advice.

| AI-Assisted Security Testing

Dynamically Constructed Custom Tool Config

Generate dynamic analysis target, paths and configuration based on application and tech stack.

Agentic Scan, Validation, Triage and PoC

Scan, validate, triage, and craft PoC code for identified vulnerabilities.

Agentic Remediation

Remediation using coding agent, verification using the PoC and automated regression testing.



AGENT-BASED PENETRATION TEST
Ranks: 1

Req: Level 20.
Deploy your advanced automated computer agents to methodically find and fix exploits in the system. Gain a 10% bonus to finding exploits and vulnerabilities when agents are active.

OK to Begin Audit Done A)
Back E)



Do any kind of security

Doing something is better than nothing.



Security mindset

Security should be a holistic initiative, not just a check in CI/CD.



Write once, execute forever

Creating checks with agents means you only pay the token tax once.

Thank you!

CLAUDE CODE MEETUP